

Controls and compliance checklist

Simulated scenario

The scope is defined as the entire security program at Botium Toys. This means all assets need to be assessed alongside internal processes and procedures related to the implementation of controls and compliance best practices.

Controls assessment checklist

Yes	No	Control
	x	Least Privilege
	x	Disaster recovery plans
	x	Password policies
	x	Separation of duties
x		Firewall <i>The existing firewall blocks traffic based on an appropriately defined set of security rules.</i>
	x	Intrusion detection system (IDS)
	x	Backups
x		Antivirus software
	x	Manual monitoring, maintenance, and intervention for legacy systems
	x	Encryption
	x	Password management system
x		Locks (offices, storefront, warehouse)
x		Closed-circuit television (CCTV) surveillance
x		Fire detection/prevention (fire alarm, sprinkler system, etc.)

Compliance checklist

Payment Card Industry Data Security Standard (PCI DSS)

Yes	No	Best practice
	x	Only authorized users have access to customers' credit card information.
	x	Credit card information is stored, accepted, processed, and transmitted internally, in a secure environment.
	x	Implement data encryption procedures to better secure credit card transaction touchpoints and data.
	x	Adopt secure password management policies.

General Data Protection Regulation (GDPR)

Yes	No	Best practice
	x	E.U. customers' data is kept private/secured.
x		There is a plan in place to notify E.U. customers within 72 hours if their data is compromised/there is a breach.
	x	Ensure data is properly classified and inventoried.
	x	Enforce privacy policies, procedures, and processes to properly document and maintain data.

System and Organizations Controls (SOC type 1, SOC type 2)

Yes	No	Best practice
	x	User access policies are established.
	x	Sensitive data (PII/SPII) is confidential/private.
x		Data integrity ensures the data is consistent, complete, accurate, and has been validated.
	x	Data is available to individuals authorized to access it.

Recommendations:

Botium Toys should prioritize the implementation of security controls that address the gaps identified during the internal audit.

Access and credential management:

Implement the principle of least privilege and separation of duties to reduce the risk of unauthorized access. Strengthen credential security by establishing password policies and implementing a secure password management system.

Detection and resilience:

Implement an intrusion detection system (IDS) to improve the organization's ability to identify potentially malicious activity. A disaster recovery plan and ongoing management of legacy systems should also be established to improve operational resilience and reduce the impact of security incidents.

Data protection and compliance:

Implement encryption controls to better protect sensitive and payment-related information. The organization should also classify and inventory its assets to support the identification of additional security requirements and improve compliance with applicable regulations and standards.